

SABA

CRM & Booking Platform для автомоек Казахстана

ТЕХНИЧЕСКОЕ ЗАДАНИЕ НА РАЗРАБОТКУ

Версия 1.4 — ФИНАЛЬНАЯ | MVP Phase 1 | Май 2026

Параметр	Значение
Версия	1.4 — Финальная. Все замечания экспертов закрыты
Дата	Май 2026
Статус	✔Утверждён Product Owner. Готов к разработке
Целевая аудитория	Full-Stack Developer + Claude AI (вайбкодинг)
Область	MVP Phase 1 — Light и Business планы. Казахстан
Phase 2	Pro план, Халык QR, Telegram Bot, AI-функции, WebKassa

1. Введение

1.1 Продукт

Saba — вертикальный SaaS для автомоек Казахстана. Позиционирование: «Цифровой директор — контролирует деньги, пока вас нет». Три USP: Анти-фрод, WhatsApp-native, Data moat.

1.2 Язык

Базовый — русский. Второй — казахский. Переключается в настройках профиля. Все строки через i18next-ключи с первого коммита. Хардкод текста запрещён.

1.3 Скоп

Фаза	Содержание
Phase 1 (это T3)	Light + Business. 17 функциональных блоков. Подписка CloudPayments.
Phase 2	Pro план. Халык QR. WebKassa. Telegram Bot. AI-функции. Лимиты AI-бота.

2. Тарифные планы

2.1 Матрица Phase 1

Функция	Light — 5 000 ₹/мес	Business — 15 000 ₹/мес
Боксы	до 4	до 8
Мастера	до 5	до 15
Записи	∞	∞
Шахматка (оба режима)	✓	✓
База клиентов + авто	✓	✓
Импорт Excel	✓	✓
Онлайн-виджет	✓	✓
Kaspi QR	✓	✓
Анти-фрод	✓	✓
Портал клиента	✓	✓
AI-поддержка 24/7	✓	✓
WA-уведомления	✗	10 000/мес
WA-рассылки	✗	✓
Аналитика	Только «Сегодня»	Полная (нед/мес)
NPS + рейтинг мастеров	✗	✓
Расчёт зарплат	✗	✓
Личный кабинет мастера	✗	✓
RFM-сегментация	✗	✓
«Powered by Saba»	✓ убрать нельзя	✓ можно скрыть
Счёт-фактура PDF	✓	✓
Триал 14 дней	Business-функции	✓

2.2 Enforcement ограничений планов

Ограничение	Как применяется	Что видит пользователь
Лимит боксов	COUNT(boxes WHERE company_id) >= plan_limit → 403 при создании	«Ваш план Light: до 4 боксов. Обновить до Business →»
Лимит мастеров	Аналогично при создании employee	«Достигнут лимит мастеров для вашего плана»
WA 10 000/мес	Redis wa:{company_id}:month. При отправке >= 10 000 → skip	Колокольчик: «Лимит WA исчерпан. Обновится 1-го числа»
Функции Business	plan_limits.has_feature проверяется в middleware	«Функция доступна в Business. Обновить →»
Подписка истекла	plan_expires_at < NOW() → companies.mode = read_only	Баннер: «Подписка истекла. Новые записи заблокированы»

2.3 Trial (14 дней)

- При регистрации: plan = business, is_trial = true, plan_expires_at = NOW() + 14 дней
- День 7: system_notification + email «Осталось 7 дней триала»
- День 14: переход в Light. Данные сохраняются. Business-функции скрываются
- Триал → конверсия: при 2 днях до конца — задача продажам написать клиенту вручную (WA)

2.4 Downgrade (Business → Light) — по модели Stripe/Notion

Шаг	Что происходит	Детали
1 — Предупреждение	Модал: список что станет недоступным	«Вы потеряете: WA-уведомления, Аналитика, NPS, Зарплаты, RFM. Боксы 5+: станут inactive»
2 — Подтверждение	Явный клик «Да, перейти на Light»	Требуется подтверждение
3 — Когда	Конец текущего периода, не немедленно	«Business активен до 1 июня. После — Light»
4 — Данные	Всё сохраняется в БД, только скрывается	WA-кампании: архив owner. NPS: сохранены. Аналитика: заморожена
5 — Боксы 5+	Переходят в status = inactive	История записей остаётся. Новые — невозможны
6 — Апгрейд обратно	Всегда доступен 90 дней	«Вернуться на Business» → данные мгновенно возвращаются

- **Физическое удаление данных при downgrade запрещено. Только сокрытие в UI.**

3. Подписка и эквайринг (CloudPayments)

3.1 Предварительные условия для запуска (prerequisites Saba)

Перед тем как принимать платежи, команда Saba должна выполнить:

Пункт	Срок	Ответственный
Регистрация ТОО «Saba» или использование существующего юрлица	До Sprint 0	CEO
Открытие расчётного счёта в КЗ банке (Kaspi Business / Halyk / Forte)	До Sprint 0	CEO
Подача заявки на мерчант-аккаунт CloudPayments KZ	День 0. Онбординг 5–10 рабочих дней	CEO
Получение HMAC-ключа для webhook (в ЛК CloudPayments)	После одобрения аккаунта	Dev
Тест рекуррентного платежа в sandbox CloudPayments	Sprint 4	Dev

□ Без мерчант-аккаунта CloudPayments функция подписки недоступна. Запустить параллельно с разработкой.

3.2 Схема рекуррентного платежа

Шаг	Действие	Детали
1	Привязка карты	CloudPayments JS Widget (iframe). Карта не касается серверов Saba. CP возвращает token
2	Сохранение токена	payment_methods.cp_token (не PAN). Последние 4 цифры для отображения
3	Ежемесячное списание	Saba вызывает CP Recurring API: /payments/charge с cp_token и amount
4	Webhook: успех	X-Content-HMAC проверен → invoices.status=paid → plan_expires_at += 30д
5	Webhook: ошибка	X-Content-HMAC проверен → dunning-логика (попытки +3/+7 дня)

3.3 Безопасность Webhook — HMAC-SHA256

CloudPayments подписывает каждый webhook. Без проверки подписи любой злоумышленник может подделать «успешный платёж» POST-запросом.

Алгоритм проверки (NestJS)

```
// В ЛК CloudPayments: Security → Webhook Secret → скопировать в env
const secret = process.env.CP_WEBHOOK_SECRET;
```

```
const body    = req.rawBody; // raw Buffer до JSON.parse
const sig     = req.headers['x-content-hmac'];
const expected = createHmac('sha256', secret)
    .update(body)
    .digest('base64');
if (sig !== expected) throw new UnauthorizedException();
// Только после проверки — обрабатываем webhook
```

□ **rawBody должен быть получен до любого middleware который парсит JSON. Использовать NestJS RawBodyModule или bodyParser.raw() для этого endpoint.**

Заголовок	Значение	Описание
X-Content-HMAC	base64(HMAC-SHA256(body, secret))	CloudPayments подписывает тело запроса

3.3.1 Webhook Idempotency — защита от двойной обработки

CloudPayments повторяет webhook при сетевых ошибках. Без проверки на дубли один платёж может продлить plan_expires_at на 60 дней вместо 30.

Реализация в обработчике

```
// В начале handleWebhook — ДО любой бизнес-логики
const existing = await db.invoices.findUnique({
  where: { cp_transaction_id: payload.transactionId }
});
if (existing?.status === 'paid') {
  return { code: 0, message: 'already_processed' }; // 200 OK — CP не будет ретраить
}
// Только если NOT EXISTS — продолжаем обработку
```

- Возвращать 200 OK при дубле — CloudPayments прекратит повторные попытки
- Возвращать 500 при дубле — CloudPayments будет ретраить бесконечно
- cp_transaction_id должен иметь UNIQUE constraint в таблице invoices

□ **Без idempotency проверки — один network retry CloudPayments создаст двойное начисление. Обязательно для любого webhook платёжной системы.**

3.5 Dunning — повторные попытки и Recovery

Клиент платит Light 5 000 ₴ 1 апреля, апгрейдится на Business 15 апреля.

Формула

```
days_remaining = plan_expires_at - NOW() // в днях (15)
days_in_period = 30
current_daily   = current_plan_price / days_in_period // 5000/30 = 166.67 ₴/день
new_daily       = new_plan_price / days_in_period      // 15000/30 = 500 ₴/день
charge_amount   = (new_daily - current_daily) * days_remaining
                = (500 - 166.67) * 15 = 5 000 ₴
```

- Минимальная сумма списания: 100 ₴ (ограничение CloudPayments). Если pro-rata < 100 ₴ → списать 100 ₴
- Новый period_to = текущий plan_expires_at (не сдвигается). Следующий полный период с plan_expires_at
- Апгрейд применяется немедленно — план меняется сразу после успешного списания

□ **Формула и пример показывается клиенту в модале апгрейда до подтверждения: «Будет списано 5 000 ₴ за оставшиеся 15 дней»**

3.5 Dunning — повторные попытки

День	Действие	Уведомление
0 (неудача)	Попытка #1: fail. system_notification + email	«Не удалось списать оплату. Проверьте карту»
+3	Попытка #2	«Второй раз не удалось. Обновите карту»
+7	Попытка #3	«Последняя попытка. Завтра доступ ограничится»
+8	mode = read_only. Grace period начался	«Доступ ограничен. Оплатите для восстановления»
+22	Финальное предупреждение	«Через 7 дней данные станут недоступны»
+29	mode = frozen	«Аккаунт заморожен. Оплатите или скачайте данные»
+60	Soft delete	Данные скрыты. Восстановление только через поддержку

3.5.1 Dunning Recovery — выход из read_only / frozen

Клиент обновил карту и успешно оплатил во время dunning или grace period. Система должна немедленно восстановить доступ.

Шаг	Действие	Детали
1	Клиент обновляет карту	POST /subscription/attach-card. Новый cp_token сохраняется как default
2	Немедленная попытка списания	Saba вызывает CP Recurring API с новой картой и суммой текущего плана
3	Webhook paid получен	HMAC проверен. Idempotency проверен.
4	Восстановление доступа	companies.mode = active. plan_expires_at = NOW() + 30 дней (новый период)
5	Уведомление	system_notification owner: «Оплата прошла успешно. Доступ восстановлен»
6	Сброс dunning счётчика	Все pending dunning jobs из Bull-очереди отменяются

- Recovery доступен на любом этапе dunning: read_only, frozen, до soft delete (день +60)
- После soft delete (день +60): восстановление только через поддержку Saba вручную
- При переходе в active из frozen: скрытые функции сразу возвращаются без перезагрузки страницы

3.6 Счёт-фактура K3 (invoices PDF)

Казахстанские компании требуют tax document для принятия расхода. Saba генерирует PDF-квитанцию при каждом успешном платеже.

Обязательное поле	Источник данных
БИН/ИИН продавца (Saba TOO)	env: SABA_BIN
Наименование продавца	env: SABA_COMPANY_NAME
Дата выставления счёта	invoices.paid_at
Номер счёта	invoices.id (короткий UUID)
Наименование услуги	«Подписка Saba [план] — [месяц год]»
Сумма без НДС	invoices.amount / 1.12 (если плательщик НДС)
НДС 12%	invoices.amount × 0.12 / 1.12
Итого с НДС	invoices.amount
БИН/ИИН покупателя	companies.bin (если указан)
Наименование покупателя	companies.name

- PDF генерируется библиотекой pdf-lib или puppeteer на Node.js при webhook paid
 - Ссылка на PDF: invoice_pdf_url в таблице invoices. Хранится в S3 (Cloud.kz)
 - Доступна для скачивания в разделе «Подписка → История платежей»
 - Если companies.bin не заполнен — квитанция без реквизитов покупателя (для ИП/физлиц)
- Если Saba не является плательщиком НДС — поле НДС = 0. Уточнить с бухгалтером при регистрации.

3.7 Схема БД — платежи

Таблица	Ключевые поля
payment_methods	id, company_id, cp_token, last_four, card_type, expires_at, is_default
invoices	id, company_id, plan, amount, status, cp_transaction_id, attempt_number, period_from, period_to, paid_at, invoice_pdf_url

4. Архитектура и стек

4.1 Принципы

- Monolith first. Event-driven внутри. Multi-tenancy + RLS.
- Mobile-First ($\geq 44 \times 44$ px). Offline PWA. i18n-first (RU/KZ).
- Серверы только в Казахстане (Cloud.kz) — Закон «О персданных» РК

4.2 Стек

Слой	Технология	Версия	Обоснование
Backend	Node.js + NestJS	v20 / 10.x	TypeScript. WABA, Kaspi, CloudPayments
Frontend	React + Next.js	15.x App Router	SSR/SSG. Server Components
Виджет	Next.js lightweight	15.x	< 100 KB bundle
БД	PostgreSQL	16.x	RLS. UNIQUE constraints. Transactions
Кэш/RT	Redis + Socket.io	7.x / 4.x	Шахматка <100ms. Slot reservation. WA счётчики
Очереди	Bull (Redis)	5.x	Async jobs. Retry. DLQ
ORM	Prisma	5.x	Type-safe. Migrations
Auth	JWT + Refresh	—	Rotation. Fingerprint binding
Эквайринг	CloudPayments	—	Recurring. Tokenization. KZT. KZ-certified
Email	Resend	—	Системные письма: invoices, dunning, trial warnings
PDF	pdf-lib	—	Генерация счёт-фактуры
Погода	OpenWeatherMap	v3.0	Прогноз 7 дней. Redis 3ч
AI Support	Claude API Sonnet	—	24/7 поддержка RU/KZ
i18n	i18next	—	RU/KZ. JSON-ключи. Нет хардкода
Деплой	Docker + Cloud.kz VPS	—	Docker Compose Phase 1
CI/CD	GitHub Actions	—	Lint → Test → Build → Deploy

4.3 PostgreSQL RLS

```
-- Два роля: app_user (runtime) и app_admin (только миграции)
CREATE ROLE app_user LOGIN PASSWORD '...';
CREATE ROLE app_admin LOGIN PASSWORD '...';
ALTER TABLE appointments ENABLE ROW LEVEL SECURITY;
```

```
-- ... для всех таблиц с company_id
CREATE POLICY tenant_isolation ON appointments
  USING (company_id = current_setting('app.current_tenant')::uuid);
// NestJS middleware: перед каждым запросом
await client.query(`SET LOCAL app.current_tenant = '${companyId}'`);
```

❑ **app_admin — ТОЛЬКО в миграциях. Никогда в runtime. Иначе RLS не защищает.**

4.4 UNIQUE constraint (fallback к Redis)

```
ALTER TABLE appointments ADD CONSTRAINT uq_box_timeslot
  UNIQUE (company_id, box_id, start_at)
  WHERE status NOT IN ('cancelled', 'no_show');
```

При недоступности Redis и одновременном бронировании — PostgreSQL вернёт UniqueViolation → API → 409 «Слот уже занят».

4.4.1 Prisma + RLS — обязательная интеграция

Prisma использует connection pool. SET LOCAL без явной транзакции не сохраняется между запросами пула — RLS тихо не работает. Это самая частая ошибка при Prisma + PostgreSQL RLS.

Реализация: Prisma Middleware + nestjs-cls

```
// nestjs-cls: хранит companyId per-request через AsyncLocalStorage
npm install nestjs-cls
// Auth Guard: после JWT-валидации устанавливает companyId
this.cls.set("companyId", jwt.companyId);
// Prisma Middleware: оборачивает каждый query в транзакцию с SET LOCAL
prisma.async (params, next) => {
  const id = cls.get("companyId");
  if (!id) return next(params);
  return prisma.async (tx) => {
    await tx();
    return next(params);
  };
};
```

❑ **Без этого middleware Prisma не изолирует tenants через RLS. Регистрировать при инициализации приложения.**

Компонент	Пакет	Назначение
nestjs-cls	nestjs-cls	AsyncLocalStorage обёртка. companyId per-request
Prisma Middleware	встроен в Prisma	Оборачивает query в транзакцию с SET LOCAL
Auth Guard	NestJS	После JWT: cls.set(companyId)
Client Portal Guard	NestJS	После OTP: cls.set(session.company_id)

4.4.2 WebSocket — NestJS Gateway + Next.js

Next.js 15 App Router (Edge Runtime) не поддерживает Socket.io без кастомного сервера. Решение: NestJS WebSocket Gateway на отдельном порту 3002.

Компонент	Технология	Порт	Назначение
HTTP API	NestJS REST	3001	Все /api/v1/* endpoints

WebSocket	NestJS @WebSocketGateway	3002	Шахматка real-time. Socket.io
Frontend	Next.js App Router	3000	UI. WS подключается к 3002 напрямую

NestJS Gateway

```
@WebSocketGateway(3002, { cors: true })
export class AppointmentsGateway {
  @SubscribeMessage("join-company")
  join(client: Socket, payload: { token: string }) {
    const { companyId } = verifyJwt(payload.token);
    client.join();
  }
}
// Emit из сервиса при изменении записи:
this.gateway.server.to().emit("appointment:updated", dto);
```

Next.js Frontend

```
const socket = io(process.env.NEXT_PUBLIC_WS_URL); // → ws://api.saba.kz/ws
socket.emit("join-company");
socket.on("appointment:updated", (data) => updateBoard(data));
// nginx: /ws { proxy_pass http://localhost:3002; Upgrade ; Connection
upgrade }
```

□ Frontend подключается **НАПРЯМУЮ** к NestJS порту 3002. НЕ через Next.js 3000. nginx проксирует /ws → 3002 с WebSocket upgrade headers.

Событие	Направление	Когда
appointment:updated	Server → Client	Любое изменение записи (статус, бокс, время)
appointment:created	Server → Client	Новая запись создана
slot:reserved	Server → Client	Слот забронирован через виджет — серый блок в шахматке
slot:released	Server → Client	TTL истёк или запись оформлена
appointment:paid	Server → Client	Для NPS popup на /booking/:code
join-company	Client → Server	При открытии шахматки. Auth через JWT

4.5 Индексы PostgreSQL

Индекс	Таблица	Поля	Назначение
idx_appt_company_date	appointments	(company_id, start_at)	Шахматка: записи компании за день
idx_appt_master_date	appointments	(master_id, start_at)	Шахматка по мастерам
idx_appt_status	appointments	(company_id, status, start_at)	Аналитика по статусам

idx_clients_phone	clients	(company_id, phone)	Автопоиск при записи
idx_clients_rfm	clients	(company_id, rfm_segment)	RFM-фильтр для рассылок
idx_nps_employee	nps_responses	(employee_id, responded_at)	Витрина NPS мастера
idx_invoices	invoices	(company_id, status)	История платежей owner
idx_notif_unread	system_notifications	(company_id, is_read, created_at)	Колокольчик
idx_delivery_log	notification_delivery_log	(appointment_id, template_name)	Бейдж на карточке

4.6 Bull DLQ

Очередь	Attempts	Backoff	При провале
wa-notifications	3	Exp: 5/15/30 мин	delivery_log.status=failed + system_notification admin
email-notifications	3	Exp: 2/10/30 мин	Логируется. Не критично
nps-requests	2	Fixed: 1ч	Пропускается
wa-campaigns	1	—	campaign.status=failed + system_notification owner
import-jobs	1	—	import_jobs.status=failed + error_report
recurring-billing	3	Fixed: 1ч	Dunning-логика
pdf-generation	2	Fixed: 5мин	Лог. Пользователь может скачать позже

5. Схема базы данных (ключевые таблицы)

Все таблицы: id (UUID PK), created_at, updated_at, deleted_at (soft delete), company_id. RLS включён везде кроме companies, users, plan_limits.

5.1 Новые/изменённые таблицы v1.4

password_reset_tokens

Поле	Тип	Описание
id	UUID PK	
user_id	UUID FK	→ users
token_hash	VARCHAR	bcrypt хэш 6-значного OTP-кода
phone	VARCHAR(20)	Телефон куда отправлен OTP
attempts	INTEGER	Неверных попыток (max 3)
expires_at	TIMESTAMP	TTL = 15 минут
used_at	TIMESTAMP	Одноразовый — обнуляется после использования

otp_rate_limits (Redis, не PostgreSQL)

Redis key	TTL	Назначение
otp_send:{phone}	300 сек (5 мин)	Cooldown между отправками OTP одному номеру
otp_attempts:{phone}:{context}	600 сек	Счётчик неверных попыток ввода кода
otp_blocked:{phone}	300 сек	Блок после 3 неверных попыток

invoices (обновлено)

Поле	Тип	Описание
invoice_pdf_url	TEXT	S3 ссылка на PDF счёт-фактуру
invoice_number	VARCHAR(50)	Читаемый номер: SABA-2026-0001
buyer_bin	VARCHAR(12)	БИН/ИИН покупателя (из companies.bin)
buyer_name	VARCHAR(255)	Наименование покупателя (из companies.name)
amount_excl_vat	DECIMAL(10,2)	Сумма без НДС

vat_amount	DECIMAL(10,2)	Сумма НДС 12%
------------	---------------	---------------

nps_responses (source обновлено)

Поле	Тип	Описание
source	ENUM	waba_link browser_popup master_interface
review_page_token_id	UUID FK	→ review_tokens (для waba_link и browser_popup)

review_tokens (страница NPS-оценки)

Поле	Тип	Описание
id	UUID PK	
appointment_id	UUID FK	→ appointments
client_id	UUID FK	→ clients
company_id	UUID FK	→ companies (для брендинга на странице)
token_hash	VARCHAR	Хэш JWT. Оригинал только в WA-сообщении
used_at	TIMESTAMP	NULL = не использован. Одноразовый
expires_at	TIMESTAMP	TTL = 48 часов

6. Функциональные требования

6.1 Wizard + Contextual Hints

Шаг	Экран	Действие	Валидация
1	Тип бизнеса	Автомойка / Детейлинг / СТО → пресет услуг	Обязательно
2	Профиль	Название, телефон, адрес, город, язык	Название + телефон обязательны
3	Боксы	Мин 1 / Макс 20. Имя + цвет	Мин 1
4	Услуги	Из пресета или свои. Цена + длительность	Мин 1
5	Сотрудники	Мастера + тип зарплаты (конструктор)	Пропустить можно
6	Режим работы	Часы по дням недели	Мин 1 рабочий день
7	Готово	Ссылка виджета, QR, чеклист	—

- Прогресс сохраняется при закрытии. Возврат — с того же шага

□ Тест: 3 реальных пользователя на мобильном ≤ 10 минут

Contextual Hints для новых пользователей

- Guided tour при первом входе admin/master поверх реального интерфейса
- 6 подсказок: Шахматка, кнопка +, карточка записи, переключатель режима, колокольчик, раздел Клиенты
- Пропустить каждую подсказку или весь тур. Перезапуск из «Помощь»
- Прогресс: users.onboarding_hints_seen (JSONB)

6.2 Авторизация — все сценарии

6.2.1 Владелец / Admin — логин

- POST /api/v1/auth/login: { phone, password } → { accessToken, refreshToken, user }
- AccessToken TTL: 15 мин. RefreshToken TTL: 30 дней + device fingerprint
- 5 неверных попыток за 1 мин с одного IP → блок 15 мин (rate limit)

6.2.2 Сброс пароля (Password Reset) — через WA OTP

Используется когда владелец или администратор забыл пароль. Канал — WA на номер телефона аккаунта.

Шаг	Действие	Детали
-----	----------	--------

1	«Забыли пароль?»	На экране входа. Пользователь вводит номер телефона аккаунта
2	WA OTP	POST /api/v1/auth/reset/send-otp: { phone }. Если телефон найден в users — WA с 6-значным кодом. TTL 15 мин
3	Ввод кода	POST /api/v1/auth/reset/verify-otp: { phone, code }. 3 попытки. После 3 неверных — блок 5 мин
4	Новый пароль	POST /api/v1/auth/reset/set-password: { reset_token, new_password }. reset_token — JWT из шага 3. TTL 10 мин
5	Завершение	Все активные сессии пользователя инвалидируются. Логин с новым паролем

- Если телефон не найден в БД: ответ тот же «Код отправлен» (не раскрывать существование аккаунта)
- Канал WA для password reset: SABA системный WABA-номер (не номер компании)

6.2.3 Мастер — PIN-вход

- POST /api/v1/auth/pin: { employee_id, pin } → { shortToken, TTL: 4ч }
- Только смена статуса записи. Никакого другого доступа

6.2.4 Клиент — портал (WA OTP)

Шаг	Детали	Канал
1 — Ввод телефона	Страница saba.kz/client. Поле «Ваш номер телефона»	—
2 — OTP	POST /auth/client/send-otp: { phone, company_slug }. Rate limit: 1 отправка / 5 мин на номер (Redis otp_send:{phone})	SABA системный WABA — не WABA компании. Не считается в лимит 10 000
3 — Проверка	POST /auth/client/verify-otp: { phone, company_slug, code }. 3 попытки. Блок 5 мин при превышении	—
4 — Сессия	session_token в cookie (HttpOnly, Secure). TTL 30 дней. Запись в client_sessions	—
5 — Light план	OTP использует SABA системный WABA — работает на обоих планах без WABA компании	Системный WABA

□ OTP для портала клиента идёт через системный WABA-номер Saba, а НЕ через WABA компании. Не считается в план 10 000 сообщений.

6.2.5 OTP Rate Limiting (общие правила)

Redis key	TTL	Описание
otp_send:{phone}	300 сек	Cooldown между отправками. Один OTP каждые 5 мин на номер
otp_attempts:{phone}:{context}	600 сек	context = reset_password client_portal client_cancel
otp_blocked:{phone}:{context}	300 сек	Блок после 3 неверных попыток

6.3 Шахматка

Режим	Ось Y	Назначение
По боксам (default)	Список боксов/постов	Администратор при записи клиентов
По сотрудникам	Список активных мастеров	Контроль занятости. Бокс — подпись на карточке

Бронирование слота (Race Condition)

Шаг	Действие
1	Клиент выбирает слот → POST /widget/:slug/reserve → Redis SETNX {key, TTL=600}
2	SETNX OK → слот забронирован. Возврат: reservation_token
3	SETNX nil → слот занят → следующий свободный
4	Завершение → POST /widget/:slug/book → appointment + DELETE Redis key
5	TTL истёк → слот освобождается автоматически
6	Redis недоступен → PostgreSQL UNIQUE constraint. 409: «Слот уже занят»

Offline PWA

- ServiceWorker кэширует: шахматку текущего + 2 дня вперёд
- Оффлайн: просмотр данных с меткой «Нет связи»
- Создание записи оффлайн: pending_sync в IndexedDB
- Восстановление: sync с сервером. Конфликт → ошибка «Слот уже занят». Запись удаляется из очереди

Бейдж уведомлений на карточке

Иконка	Значение
□ серый	Pending — ещё не отправлено
✓ зелёный	Delivered (из WABA webhook)
✗ красный	Failed. Клик → причина + «Повторить» или «wa.me/номер»
— нет	Клиент без WA согласия

Быстрая запись (форма)

Поле	Поведение
------	-----------

Телефон	≥10 цифр → поиск. Найден: имя+авто+история+NPS. Не найден: «Новый клиент»
Авто	Select из авто клиента. «+ Добавить» → марка + номер + размер S/M/L/XL
Услуга	Цена автоматически по car_size
Бокс / Мастер / Время	Предзаполнены при клике на слот

□ ≤15 сек при клиенте в базе, ≤30 сек при новом

6.4 NPS — сбор оценок (без email)

Канал	Кто	Когда	Как
WA-ссылка	Клиент	Через 1ч после paid: WA-сообщение с /review/:token	Страница saba.kz/review/:token в браузере
Browser popup	Клиент (если вкладка открыта)	При смене статуса на paid: Socket.io → popup на /booking/:code	Overlay «Оцените визит» → ★1–5
Интерфейс мастера	Мастер	После нажатия «Завершить» (done), перед следующей записью	Полноэкранный модал ★1–5 + комментарий (опц)

Страница /review/:token — с брендингом мойки

Страница показывает брендинг конкретной мойки — повышает доверие и конверсию оценок.

Элемент	Источник данных	Описание
Название мойки	companies.name	Крупный заголовок вверху страницы
Акцентный цвет	companies.settings.accent_color	СТА кнопки и активные элементы в цвете мойки
Имя мастера	employees.name (через appointment)	«Оцените работу мастера [имя]»
Услуга + дата	appointments.service + start_at	Контекст: что и когда было сделано
Шкала оценки	—	★★★★★ кликабельные звёзды (1–5)
Комментарий	—	Textarea. Необязательно
После отправки	—	«Спасибо! Ваш отзыв помогает [название мойки]» + кнопка «Записаться снова»

- Токен = JWT: payload { appointment_id, client_id, company_id }. TTL 48ч. Доставляется через WA

- Повторное открытие: «Вы уже оставили отзыв» — без ошибки, без redirect
- Страница SSR (Next.js) — индексируется как обычная страница

wa_opt_out vs NPS — правило

Явное решение: что блокируется при wa_opt_out = true.

Тип сообщения	wa_opt_out = false	wa_opt_out = true
appointment_confirmed (транзакционное)	✓ Отправляется	✓ Отправляется
appointment_reminder (транзакционное)	✓ Отправляется	✓ Отправляется
payment_request (транзакционное)	✓ Отправляется	✓ Отправляется
nps_request (сервисное)	✓ Отправляется	❑ НЕ отправляется
marketing campaign (маркетинговое)	✓ При wa_consent=true	❑ НЕ отправляется

❑ Транзакционные сообщения (confirm, reminder, payment) не блокируются opt_out — это функциональные уведомления об услуге. NPS и рассылки блокируются.

6.5 Портал клиента — лучшие практики

Авторизация (WA OTP через системный WABA Saba)

Шаг	Действие
1	Клиент вводит телефон на saba.kz/client (или переходит из WA-сообщения)
2	POST /auth/client/send-otp → WA с кодом с системного номера Saba. Rate limit: 1/5 мин
3	Клиент вводит 6-значный код. 3 попытки. Блок 5 мин при превышении
4	Сессия: session_token в cookie HttpOnly Secure. TTL 30 дней
5	Повторный визит: cookie активна → сразу в кабинет без OTP

Что видит клиент

Раздел	Содержание
Предстоящие записи	Дата, время, услуга, мастер. Кнопка «Отменить» (только до confirmed и >1ч)
История визитов	Все прошлые: дата, услуга, сумма, мастер, своя оценка
Мои авто	Список авто, госномера, размеры. Редактирование
Записаться снова	Быстрая форма: авто из истории предзаполнено

Уведомления	Управление: wa_consent, wa_opt_out
-------------	------------------------------------

□ Клиент видит ТОЛЬКО свои данные своей мойки. RLS: client_sessions.company_id изолирует арендаторов.

Доступ из WA-сообщений

- appointment_confirmed → кнопка «Мой аккаунт» → saba.kz/client?phone={phone} (ОТР если нет сессии)
- appointment_reminder → кнопка «Отменить запись» → одноразовая ссылка отмены без входа
- nps_request → кнопка «Оценить» → /review/:token (без авторизации в портале)

6.6 Конструктор зарплатных правил

Тип правила	Поля настройки	Пример
Процент от услуги	% + все / конкретные услуги	«35% от каждой услуги»
Фикс за смену	Сумма ₸	«5 000 ₸ за рабочий день»
Фикс в месяц	Сумма ₸/мес	«100 000 ₸ в месяц»
Бонус за порог	Порог ₸ + % сверх + период (день/нед/мес)	«15% от выручки сверх 200 000 ₸/мес»

- Несколько правил суммируются. Порядок — drag-and-drop
- Конфликт правил не разрешается алгоритмически — ответственность владельца
- Изменение вступает в силу со следующего начисления

6.7 Kaspi QR оплата

Сценарий	Шаги
Боевой	done → «Принять оплату» → Kaspi QR → клиент сканирует → webhook → paid → зарплата
Workaround	Статический QR → клиент показывает уведомление → «Оплачено» + 4 цифры транзакции

6.8 WhatsApp уведомления (Business + системные)

Два WABA-номера

WABA-номер	Назначение	Считается в лимит
SABA системный WABA	ОТР (portals, password reset). НЕ привязан к мойке	Нет. Системные расходы Saba

WABA компании (мойки)	appointment_confirmed, reminder, nps_request, campaigns	Да. Лимит 10 000/мес на Business
-----------------------	---	----------------------------------

Шаблоны (WABA компании)

Шаблон	Триггер	Ключевые переменные
appointment_confirmed	Создание/подтверждение записи	name, date, time, box, address, portal_link, cancel_link
appointment_reminder	За 2 часа (cron)	name, time, service, cancel_link
appointment_cancelled	Отмена	name, date, time, booking_link
payment_request	Статус → done	name, amount, qr_url
nps_request	Через 1ч после paid (cron). ТОЛЬКО если wa_opt_out=false	name, master_name, review_link

6.8.1 Cancel Link — страница отмены записи без входа

appointment_confirmed и appointment_reminder содержат cancel_link — одноразовая ссылка отмены записи без необходимости входить в портал клиента.

Параметр	Значение	
URL	saba.kz/cancel/:token	
Токен	JWT: { appointment_id, client_id, company_id }. TTL = до времени записи + 30 мин. Одноразовый	
Auth	Без входа в систему. Токен в URL — достаточно	
Доступен когда	Статус записи: pending или confirmed. Время записи > 60 минут вперёд	
Сценарий	Что показывает страница	Действие системы
Запись можно отменить	Детали записи: дата, время, услуга, мастер. Кнопка «Отменить запись»	appointment.status = cancelled. cancel_reason = 'client_via_wa_link'. WA-уведомление администратору
Запись уже отменена	«Эта запись уже отменена»	Нет действий. Показать кнопку «Записаться снова»
Запись в статусе in_progress или done	«Запись уже выполняется — отмена невозможна»	Нет действий. Показать контакт мойки
Токен истёк (после времени записи + 30 мин)	«Ссылка устарела»	Нет действий. Показать кнопку «Записаться снова»

Токен использован повторно	«Вы уже отменили эту запись»	Нет действий
----------------------------	------------------------------	--------------

- После отмены: страница показывает «Запись отменена. Хотите записаться снова? →» (ссылка на виджет)
- Отмена через `cancel_link` фиксируется в `audit_log` с `cancelled_by = client` и `source = wa_cancel_link`
- Администратор получает `system_notification`: «Клиент [имя] отменил запись на [дата] через WhatsApp»
 - `cancel_link` генерируется при создании каждой записи и сохраняется в `appointments.cancel_token_hash`. При отмене — токен инвалидируется (`cancel_token_used_at = NOW()`).
- Fallback: SMS через KazInfoTech при недоступности WABA (3 ошибки подряд)

6.9 Маркетинговые WA-рассылки (Business)

Параметр	Правило
Аудитория	<code>wa_consent=true AND wa_opt_out=false</code> (всегда, без исключений)
Интервал	Минимум 7 дней между рассылками одному клиенту (per company, не global)
Время	09:00–21:00 по timezone компании
Лимит	Совместный с другими WA-сообщениями. Всего 10 000/мес на Business
Результат	Delivered / Read / Failed через WABA webhook → <code>wa_campaign_logs</code>

6.10 Анти-фрод + Системные уведомления

Правило	Логика	Кто обходит
Запрет удаления	<code>in_progress+</code> → только <code>cancelled</code> с <code>cancel_reason</code>	Только owner
Защита цены	Admin меняет цену ниже <code>original_price</code> только с 4-значным кодом	Код задаёт owner
Лог цен	<code>price_changes</code> — неудаляем	—
Финальные статусы	<code>paid/cancelled</code> → никуда (API + FSM)	—

Системные уведомления (колокольчик)

Событие	Кому	Текст
Отмена из <code>in_progress</code>	owner	«[Имя] отменил запись #ID в статусе «В работе». Причина: [текст]»
3+ отмены одним сотрудником за день	owner	«[Имя] отменил 3 записи из <code>in_progress</code> за сегодня»

Изменение цены ниже прайса	owner	«Цена записи #ID изменена с X Т на Y Т — [имя]»
WA не доставлено	admin	«Клиент [имя] не получил подтверждение. Напишите вручную»
WA-лимит исчерпан	owner	«Лимит 10 000 WA исчерпан. Обновится 1-го числа»
Платёж не прошёл	owner	«Не удалось списать оплату. Проверьте карту»
Триал: 7 дней	owner	«Пробный период заканчивается через 7 дней»

6.11 Импорт данных из Excel

Сущность	Обязательные поля	Опциональные поля
Клиенты	Телефон	Имя, марка авто, госномер, размер авто, кол-во визитов, сумма трат, RFM-сегмент
Услуги	Название, Длительность (мин), Цена	Цены S/M/L/XL, Категория
Сотрудники	Имя	Телефон, Роль (master/admin — default: master)

Стратегия транзакций — crash recovery

Если Bull worker упал в середине импорта 1 000 строк — данные не теряются и нет дублей.

Шаг	Детали
Batch processing	Импорт разбивается на батчи по 50 строк
Checkpoint	После каждого батча: import_jobs.processed_rows обновляется + cursor (last_processed_row_index)
Crash recovery	При перезапуске job: читает checkpoint, начинает с (cursor + 1)-й строки
Транзакция батча	Каждые 50 строк — одна PostgreSQL транзакция. Успех → commit. Ошибка в батче → rollback только этого батча, ошибки в error_rows
Idempotency	Upsert по phone (для клиентов): INSERT ... ON CONFLICT (company_id, phone) DO UPDATE

- Прогресс в UI: polling каждые 3 сек или WebSocket. $\text{progress_percent} = \frac{\text{processed_rows}}{\text{total_rows}} \times 100$
- Timeout job: 10 минут. После → status = failed + error_report с обработанными строками

6.12 Дашборд

«Сегодня» (все планы)

Метрика	Формула
Выручка сегодня	SUM(price) WHERE paid AND today + тренд к вчера ↑ ↓ %
Нал / Kaspi	Разбивка по payment_method

Записей / Неявки	COUNT. Неявки + потерянная выручка T
Загрузка боксов	(занятые часы / рабочие часы) × 100% — прогресс-бар

«Аналитика» (Business, нед/мес)

Метрика	Визуализация
Выручка по дням	Столбчатый график. Период нед/мес/квартал
Текущий vs прошлый период	Два ряда на одном графике
Топ-3 услуги и мастера	Bar chart и список
Спящие клиенты	Число + кнопка «Запустить рассылку»

Погода (оба плана)

Параметр	Значение
API	OpenWeatherMap One Call v3.0. Координаты: companies.weather_lat/lon
Кэш	Redis TTL 3ч. Cron каждые 3ч
Данные	7 дней: иконка + темп макс/мин + описание
Логика	Дождь/снег → «Ожидайте рост записей — предложите клиентам забронировать заранее»
Fallback	API недоступен → виджет скрывается. Дашборд не блокируется

6.13 AI-поддержка 24/7

Параметр	Значение
Модель	Claude API Sonnet
Языки	RU/KZ — по language пользователя
Контекст	System prompt: документация Saba + текущий план + роль + FAQ
Ограничения	Нет доступа к данным мойки. Только помощь по функциям
Эскалация	3 неудачных ответа подряд → «support@saba.kz»
Лимиты	Phase 2. Phase 1: без лимита (мониторить расходы в Sentry)

6.14 Offboarding

Сценарий	Grace Period	Доступ	Данные
Подписка истекла	14 дней	Read-only + экспорт	Не удаляются
Отменил вручную	30 дней	Read-only + экспорт	Не удаляются

Dunning провалился	21 день	Read-only → frozen	Не удаляются
Аккаунт удалён	90 дней	Нет. Восстановление через поддержку	Soft delete
90 дней после удаления	—	Невозможно	Физическое удаление. x3 предупреждения

- Раздел «Мои данные» → «Скачать всё» → ZIP: clients.csv, appointments.csv, salary_accruals.csv, invoices.csv

☐ **Физическое удаление через 90 дней. Закон «О персданных» РК.**

7. Роли и права (RBAC)

Функция	Owner	Admin	Master
Шахматка (оба режима)	✓ Все	✓ Все	✓ Только свои
Создание записи	✓	✓	✗
Изменение статуса	✓ Любой	✓ Любой	✓ in_progress / done
Изменение цены	✓ Без кода	✓ С кодом owner	✗
Отмена записи	✓	✓ + комментарий	✗
Оценка визита (NPS)	—	—	✓ После done
Клиенты	✓ Полностью	✓ Телефон замаскирован	✗
Экспорт базы клиентов	✓ С 2FA	✗	✗
Импорт Excel	✓	✓	✗
Дашборд — финансы	✓	✗	✗
Зарплата своя	✓	✗	✓
NPS всех мастеров	✓	✗	✗
NPS своё	✓	✗	✓
WA-рассылки	✓	✓	✗
Конструктор зарплат	✓	✗	✗
Подписка и оплата	✓	✗	✗
Счёт-фактура (скачать)	✓	✗	✗
Аудит-лог	✓	✗	✗
Системные уведомления	✓ Все	✓ Свои	✗
Портал клиента	Отдельная роль	Отдельная роль	Отдельная роль

- JWT claims: { sub: user_id, role, company_id }
- @Roles() декоратор + Guard: role + company_id на каждом endpoint
- Портал клиента: отдельный cookie-auth через client_sessions

8. API-спецификация

REST API. Base URL: /api/v1/. JSON. JWT Bearer. Swagger: /api/docs.

8.1 Авторизация

Met hod	Path	Описание
POST	/api/v1/auth/login	{ phone, password } → { accessToken, refreshToken }
POST	/api/v1/auth/refresh	Обновление токенов
POST	/api/v1/auth/logout	Инвалидация refresh token
POST	/api/v1/auth/register	{ company_name, phone, password } → триал
POST	/api/v1/auth/pin	Мастер PIN: { employee_id, pin } → shortToken 4ч
POST	/api/v1/auth/reset/send-otp	Password reset: { phone }. WA OTP с системного WABA. Rate limit 1/5мин
POST	/api/v1/auth/reset/verify-otp	{ phone, code } → reset_token JWT (TTL 10мин). 3 попытки
POST	/api/v1/auth/reset/set-password	{ reset_token, new_password }. Инвалидирует все сессии
POST	/api/v1/auth/client/send-otp	Портал клиента: { phone, company_slug }. Rate limit 1/5мин
POST	/api/v1/auth/client/verify-otp	{ phone, company_slug, code } → session cookie

8.2 Записи

Met hod	Path	Роль	Описание
GET	/api/v1/appointments	admin+	Query: date, box_id, master_id, status, view(boxes masters)
POST	/api/v1/appointments	admin+	Создать запись
PATCH	/api/v1/appointments/:id/status	admin+	FSM-переход статуса
PATCH	/api/v1/appointments/:id/price	owner admin	Цена. Код для admin
POST	/api/v1/appointments/:id/cancel	admin+	Отмена + cancel_reason

POST	/api/v1/appointments/id/payment	admin+	Оплата
POST	/api/v1/appointments/id/master-nps	master	Оценка мастера 1–5 после done

8.3 Виджет и NPS

Method	Path	Описание
GET	/w/:slug	SSR виджет
POST	/api/v1/widget/:slug/reserve	Бронировать слот (Redis NX TTL 600)
POST	/api/v1/widget/:slug/book	Создать запись. 409 при UNIQUE conflict
GET	/w/:slug/booking/:code	Статус записи. WebSocket-подписка на paid-событие → роруп NPS
GET	/w/review/:token	Страница NPS с брендингом мойки (SSR, без авторизации)
POST	/api/v1/nps/submit	Сохранить оценку клиента по JWT-токену

8.4 Подписка

Method	Path	Описание
GET	/api/v1/subscription	План, следующее списание, история invoices + PDF ссылки
POST	/api/v1/subscription/attach-card	Привязать карту через CloudPayments token
POST	/api/v1/subscription/upgrade	{ plan: business }. Pro-rata расчёт + немедленное списание
POST	/api/v1/subscription/downgrade	{ plan: light }. Применяется в конце периода
POST	/api/v1/subscription/cancel	Отменить. Переход в Light в конце периода
POST	/api/v1/webhooks/cloudpayments	CloudPayments webhook. HMAC-SHA256 signature check обязателен

8.5 FSM статусов

Из	В	Условие	Кто
pending	confirmed	—	admin, owner
pending	cancelled	—	admin, owner, system

confirmed	in_progress	—	admin, owner, master (PIN)
confirmed	cancelled	cancel_reason обязателен	admin, owner
confirmed	no_show	Авто: +30 мин, cron каждые 15 мин	system
in_progress	done	Затем: экран оценки у мастера	admin, owner, master (PIN)
done	paid	Оплата принята + PDF invoice генерируется	admin, owner
done	cancelled	cancel_reason + audit_log	owner only

□ **paid → любой: ЗАПРЕЩЕНО. cancelled → любой: ЗАПРЕЩЕНО.**

9. Дизайн-система

Цвет	HEX	Применение
Navy	#0D1F3C	Шапка, заголовки
Blue	#1B4F8A	Акценты
Accent	#2D6BE4	СТА кнопки
Green	#059669	Успех, оплачено
Amber	#D97706	Предупреждения, VIP
Red	#DC2626	Ошибки, отмены
Gray 50	#F9FAFB	Фон
Gray 900	#111827	Основной текст

Ключевые экраны (Figma)

Экран	Моб	Десктоп	P
Wizard (7 шагов)	✓	✓	P0
Шахматка по боксам	✓ Н- scroll	✓	P0
Шахматка по мастерам	✓	✓	P0
Быстрая запись (модал)	✓	✓	P0
Виджет записи (4 шага)	✓	—	P0
Страница /review/:token (с брендингом мойки)	✓	—	P0
Дашборд (Сегодня + Аналитика + Погода)	✓	✓	P0
Принять оплату (модал)	✓	✓	P0
Password Reset (ввод телефона → OTP → новый пароль)	✓	✓	P0
Портал клиента: OTP-вход	✓	—	P1
Портал клиента: история визитов	✓	✓	P1
Конструктор зарплат	—	✓	P1

NPS-витрина мастера	—	✓	P1
Настройки подписки + карта + invoices PDF	✓	✓	P1
Downgrade warning модал	✓	✓	P1
Апгрейд: pro-rata расчёт + подтверждение	✓	✓	P1
Импорт Excel: прогресс-бар + результат	—	✓	P2
WA-кампании	—	✓	P2
Аудит-лог	—	✓	P2

10. Sprint Plan (14 недель)

Sprint	Недели	Deliverables	Критерий приёмки
0	Нед 0	Инфра: Docker, PG+RLS+индексы+UNIQUE, Redis, NestJS+i18n, Next.js, CI/CD. CloudPayments sandbox аккаунт получен. SABA системный WABA для OTP подан	Staging deploy. RLS applied. i18n RU/KZ. CloudPayments sandbox работает
1	Нед 1–2	Auth: login/refresh/logout/register/PIN. Password Reset (WA OTP). Wizard 1–4. Сущности: companies, boxes, services, employees, plan_limits. Plan enforcement	Вход работает. Password reset: OTP→новый пароль. Wizard сохраняет прогресс. Лимиты enforced
2	Нед 3–4	Wizard 5–7 + Contextual Hints. Шахматка оба режима + WebSocket. Быстрая запись. Slot reservation (Redis + UNIQUE fallback). Offline PWA	Wizard ≤10 мин. WebSocket <100ms. Race condition защита. Offline: данные видны, конфликт → ошибка
3	Нед 5–6	CRM: clients + client_cars + RFM cron + rfm_settings. Конструктор зарплат (salary_rules). Kaspi QR workaround. Импорт Excel (batch + checkpoint + progress WebSocket)	Клиент по телефону. RFM cron. Import: прогресс в реальном времени. Crash recovery
4	Нед 7–8	CloudPayments: карта + recurring + webhook HMAC + dunning. Pro-rata апгрейд с расчётом. Счёт-фактура PDF. WA оба номера (системный + компании). Delivery log + бейджи. Колокольчик. Антифрод. RBAC	HMAC webhook не пропускает поддельные запросы. PDF генерируется при paid. OTP с системного WABA
5	Нед 9–10	NPS: WA-ссылка + брендинг мойки на /review/:token + Socket.io роруп + оценка мастера. Портал клиента (OTP + история + отмена + уведомления). WA-рассылки. Погода	NPS страница с лого и цветами мойки. Портал: только свои данные (RLS test). wa_opt_out не блокирует confirm/reminder
6	Нед 11–12	Дашборд: Сегодня + аналитика. Downgrade flow. Offboarding + ZIP export. AI-бот. notification_delivery_log retention. «Powered by Saba». Triggered task на конверсию триала	Downgrade применяется в конце периода. Экспорт ZIP работает. AI-бот RU/KZ
7	Нед 13–14	QA full. Bug fixing. Lighthouse ≥85. OWASP ZAP. k6 100 VU. RLS penetration test. Финальный чеклист	Lighthouse ≥85. p95 <200ms. Company A не видит данные Company B. Webhook HMAC: reject на неверной подписи

11. Критические тест-кейсы

Тест	Ожидаемый результат
Password Reset: OTP на телефон → ввод кода → новый пароль	Все сессии пользователя инвалидированы. Новый пароль работает
Password Reset: 3 неверных кода подряд	Блок 5 мин. Кнопка «Повторить через 5 мин»
OTP send rate limit: 2 запроса за 3 мин	Второй запрос → 429 «Попробуйте через N минут»
Webhook CloudPayments: неверная HMAC подпись	401 Unauthorized. Invoice не создаётся
Webhook CloudPayments: корректная подпись + paid	invoices.status=paid. plan_expires_at += 30д. PDF генерируется
Pro-rata апгрейд на 15-й день из 30	Списано ~5 000 Т (половина разницы). План меняется немедленно
Downgrade запланирован → до даты: Business функции	WA работает. Аналитика доступна. Боксы 5+ активны
Downgrade применился → на следующий день после даты	WA заблокирован. Боксы 5+ inactive. Данные видны (не удалены)
Race condition: 2 клиента бронируют один слот	Только один получает. Второй видит следующий свободный
Redis недоступен при бронировании	PostgreSQL UNIQUE → 409 «Слот уже занят»
Offline → создание записи → слот занят при sync	Ошибка «Слот занят». Запись из IndexedDB удалена
NPS /review/:token: страница показывает лого мойки	companies.name и accent_color применены на странице
NPS: клиент с wa_opt_out=true	nps_request НЕ отправлен. appointment_confirmed — отправлен
OTP портала: с системного WABA Saba (не компании)	Счётчик 10 000/мес компании не изменился
Портал клиента: данные другой мойки	0 строк. RLS через client_sessions.company_id
Import 1000 строк: worker crash на строке 400	Перезапуск с строки 401. Нет дублей. Checkpoint работает
Счёт-фактура PDF: БИН Saba в документе	Корректные реквизиты. Скачивается из /subscription
RLS: Company A запрашивает appointments Company B	0 строк (прямой SQL без app-layer)

Plan enforcement: Business создаёт 9-й бокс	403 с текстом апгрейда
RBAC: master создаёт запись	403 Forbidden

12. Инфраструктура

12.1 Cron Jobs

Job	Расписание	Описание
appointment_no_show	Каждые 15 мин	confirmed + 30 мин → no_show
nps_send	Каждый час	WA /review/:token через 1ч после paid (wa_opt_out=false)
rfm_recalculate	Ежедн. 03:00	Пересчёт rfm_segment всех компаний
weather_update	Каждые 3ч	Обновление Redis-кэша погоды
wa_campaign_scheduler	Каждые 5 мин	Запуск запланированных кампаний
plan_expiry_check	Ежедн. 09:00	Уведомления за 7 и 3 дня
wa_usage_reset	1-го числа 00:01	Сброс wa:{company}:month в Redis
dunning_retry	Каждые 4ч	Повторные попытки списания (+3/+7 день)
notification_log_cleanup	1-го числа 04:00	Удалить партии delivery_log старше 90 дней
trial_conversion_task	Ежедн. 10:00	Создать задачу продажам при is_trial=true AND expires_in <= 2 дня

12.2 Docker Compose

Сервис	Образ	Назначение
postgres	postgres:16	БД + RLS. Volume /data/postgres
redis	redis:7	Кэш + Bull + reservations + WA счётчики + OTP rate limits
api	NestJS custom	Backend. Port 3001
web	Next.js custom	Frontend + Widget + Review + Client Portal. Port 3000
worker	Node.js custom	Bull workers + crons + DLQ handlers + PDF generation
nginx	nginx:alpine	Reverse proxy. 80/443. SSL termination

13. Риски

Риск	Вер.	Влияние	Митигация
WABA верификация 4–8 нед	Высокая	Критично	Подать Day 1. Fallback SMS. Phase 2: Telegram Bot
CloudPayments онбординг 5–10 дней	Средняя	Критично	Запустить параллельно с регистрацией TOO. Начать до Sprint 0
Meta блокирует WABA	Средняя	Критично	opt_out проверка. 7-дневный интервал. Согласованные шаблоны
Kaspi Pay API недоступен	Средняя	Высокое	Workaround: ручной QR + 4 цифры
CloudPayments webhook спуфинг	Низкая	Критично	HMAC-SHA256 валидация на каждом запросе
14 недель — 1 разработчик	Высокая	Критично	Жёсткий скоп. Еженедельные демо. Claude AI
Данные между тенантами	Низкая	Критично	RLS + UNIQUE + penetration test Sprint 7
Системный WABA Saba для OTP	Средняя	Высокое	Получить отдельный WABA-номер для системных OTP в Sprint 0

14. Чеклист запуска Phase 1

Предварительные условия (до Sprint 0)

Пункт	Статус
TOO Saba зарегистрировано (или существующее юрлицо используется)	☐
Банковский счёт в КЗ открыт	☐
Мерчант-аккаунт CloudPayments подан и одобрен	☐
HMAC webhook-ключ CloudPayments получен и в env	☐
WABA компании подан (мойка-номер)	☐
Системный WABA Saba для OTP подан	☐
OpenWeatherMap API ключ получен	☐
Domain saba.kz + admin.saba.kz зарегистрированы	☐
Cloud.kz VPS арендован, SSL настроен	☐
БИН/ИИН Saba для счёт-фактуры в env	☐

Продукт

Пункт	Статус
Wizard ≤ 10 мин — 3 пользователя на мобильном	☐
Password Reset: OTP → новый пароль. Все сессии инвалидированы	☐
Шахматка оба режима + offline PWA (конфликт → ошибка)	☐
Race condition: Redis NX + UNIQUE fallback	☐
Антифрод: колокольчик при каждом событии	☐
NPS: страница /review/:token с брендингом мойки	☐
NPS: wa_opt_out=true блокирует nps_request, не confirm/reminder	☐
Портал клиента: OTP через системный WABA Saba (не компании)	☐
Портал: RLS — клиент видит только свою мойку	☐
Downgrade: применяется в конце периода. Данные не удаляются	☐
Import Excel: batch commits, checkpoint, crash recovery	☐
Виджет < 2 сек на 4G. «Powered by Saba»	☐
AI-бот отвечает на RU и KZ	☐

Оплата

Пункт	Статус
CloudPayments: привязка карты через JS Widget	☐
Recurring charge: webhook HMAC проверяется. Поддельный → 401	☐
Pro-rata при апгрейде: формула верна. Показывается клиенту до оплаты	☐
Dunning: 3 попытки → read_only → frozen	☐
Счёт-фактура PDF: БИН Saba + реквизиты. Генерируется при paid	☐
Invoices доступны для скачивания в разделе «Подписка»	☐
OTP: rate limit 1/5 мин. Блок после 3 неверных попыток	☐

Безопасность

Пункт	Статус
RLS penetration test: Company A не видит данные Company B (прямой SQL)	☐
RBAC: master создаёт запись → 403	☐
CloudPayments webhook: отклонение при неверной HMAC подписи	☐
Rate limiting: /auth/login 5 попыток/мин. OTP 1/5 мин	☐
Все API ключи только в env. Нет в коде или git	☐

Юридическое и локализация

Пункт	Статус
Оферта + согласие на персданные при регистрации	☐
Право на удаление данных (кнопка в настройках)	☐
RU/KZ переключение на всех экранах включая /review/:token	☐
Счёт-фактура соответствует требованиям НК РК	☐

15. Глоссарий

Термин	Определение
Шахматка	Интерактивный календарь-сетка. Ось Y = боксы или мастера. Ось X = время
Тенант	Компания (мойка) в Saba. Данные изолированы через RLS
RLS	Row Level Security — политики изоляции данных на уровне PostgreSQL СУБД
WABA	WhatsApp Business API — официальный API Meta для бизнес-сообщений
Системный WABA Saba	Отдельный WABA-номер Saba для системных OTP (portal, password reset). Не WABA мойки
Kaspi QR	Оплата через QR-код приложения Kaspi.kz
CloudPayments	Платёжный сервис. Recurring billing. Tokenization. KZT. KZ-certified
HMAC-SHA256	Алгоритм проверки подписи CloudPayments webhook. <code>createHmac(sha256, secret).update(body).digest(base64)</code>
Pro-rata	Пропорциональный расчёт стоимости при апгрейде плана в середине периода
Dunning	Автоматические повторные попытки списания при неудаче. 3 попытки + grace period
Downgrade	Переход с дорогого плана на дешёвый. Применяется в конце периода. Данные не удаляются
Grace Period	Период после истечения подписки когда данные доступны для чтения и экспорта
Счёт-фактура	Налоговый документ КЗ. Генерируется PDF при каждом успешном платеже
Password Reset	Сброс пароля через WA OTP на телефон аккаунта. Инвалидирует все сессии
OTP	One-Time Password — одноразовый 6-значный код. TTL 15 мин. Rate limit 1/5 мин
FSM	Finite State Machine — конечный автомат переходов статусов записи
RFM	Recency/Frequency/Monetary — сегментация клиентов по поведению
NPS	Net Promoter Score — оценка 1–5. Без email. WA-ссылка + browser popup + интерфейс мастера
Slot Reservation	Redis SETNX TTL 600. Временная блокировка слота при оформлении виджет-записи
DLQ	Dead Letter Queue — обработка проваленных Bull-задач с retry и логированием

Batch commits	Импорт Excel разбит на батчи по 50 строк с checkpoint для crash recovery
i18n	Internationalisation — RU/KZ через i18next-ключи. Хардкод строк запрещён
Powered by Saba	Строка на виджете. Вирусная механика. Light: убрать нельзя. Business: опционально
Contextual Hints	Guided tour при первом входе. Подсказки поверх UI

— Конец документа —

Saba · ТЗ v1.4 ФИНАЛЬНАЯ · Май 2026 · КОНФИДЕНЦИАЛЬНО

Все замечания экспертов закрыты. Готов к разработке.